COS20030

Malware Analysis

Lab 12

YARA

SWINBURNE UNIVERSITY OF TECHNOLOGY

Purpose

In this lab, we are going to learn how to write Yara rules.
We will create Yara rules to detect samples of specific malware families.

Exercise 1: Hello World

Purpose: In this exercise, we are going to write a very simple Yara rule.

1. Extract lab12.zip with the password “infected”
2. Inside the lab12 directory create a new text file and write a Hello World yara rule as below.

```
rule hello_world {

strings:

   $a=”Hello World”

condition:
   $a
}
```

3. Now save the text file as helloworld.yara. This rule will match any file that has the string “Hello World” in it regardless of the file type. This means that scanning your current directory with Yara against this rule will match the rule itself because of the presence of the “Hello World” string in it.

4. Open a CMD window and navigate to the lab12 directory.
5. Scan the directory for the files matched with the helloworld.yara rule using the command below.

```
yara64.exe -r helloworld.yara .
```

6. The scan should result in finding the helloworld.yara file.

Exercise 2: Warm-up

Purpose: Write a simple Yara rule that finds other Yara rules.
To detect Yara rules with a rule, we need to define strings that are mandatory parts of a rule. As Metadata is an optional section of a Yara rule, we can focus on the titles of the other sections.

1. Create a new text file and write the following Yara rule into the file.
2. Save it as find_yara_rules.yara

```
rule yara_rules {
strings:

   $a1 = "rule "
```

```
    $a2 = "strings:"
    $a3 = "condition:"

condition:
  all of them
}
```

3. Scan the current directory to find files matched with the “find_yara_rules.yara” Yara rule.

```
yara64.exe -r find_yara_rules.yara .
```

4. The scan should result in finding the helloworld.yara file as well as the match_yara_rules.yara file.

Use strings in Yara rules

There are multiple options to use when you want to add a string to a Yara rule. You can look for ASCII or Unicode strings, you can define case-sensitivity or even look for base64-encoded or single-character XOR encrypted strings for more advanced options.
The following list shows how to use different options when defining a string in a Yara rule.

```
$a=”mystring”
$a=”mystring”  fullword
$a=”MyString” nocase
$a=”mystring”  wide
$a=”mystring”  wide ascii
$a=”mystring”  fullword ascii wide nocase
$a=”mystring”  xor
$a=”mystring”  base64
```

To extract strings from binary files, you can use the Strings utility from the Sysinternals suite. Simply execute the strings.exe and give it the file path which you want to extract the ASCII strings from.

```
strings.exe <file_path>
```

OR use the option -a or -u to extract the Unicode strings

```
strings.exe -a <file_path>
strings.exe -u <file_path>
```

In case you want to search for a specific string in the output and filter out everything else, you can pipe the output to findstr utility as shown below. The ‘/i’ option is used to look for the string regardless of the case.

```
strings.exe -a <file_path> | findstr “<string_to_look_for>”
strings.exe -a <file_path> | findstr /i “<string_to_look_for>”
```

PE module

Different modules are developed to extend the capabilities of Yara in finding characteristics in files. One of these modules is the PE module. The PE module allows you to create more fine-grained rules for PE files by using attributes and features of the PE file format.
Go to the webpage of the PE module and get yourself familiar with different capabilities.
https://yara.readthedocs.io/en/stable/modules/pe.html
To use the PE modules, simply add a line at the beginning of the Yara rule to import this module.

```
import "pe"
```

Exercise 3 - XtremeRat

Purpose: Write a Yara rule that matches the XtremeRAT malware family

1. Open lab12_dataset/malicious directory. Inside this directory, you have samples of several malware families. The names of the samples from each family start with the name of the family.
2. Find the malware samples from the “xtremerat” family.
3. Use strings.exe or DiE (Or any other tool of preference) to extract strings from one of the malware samples from this family.
4. Write a YARA rule for the XtremeRat family that:
    - Matches all ten XtremeRat malware samples in the directory
    - Does not match any other files in malicious or benign directories
    - Check that the file is a PE file
    - Contains at least five non-generic strings
    - Uses at least two of the following string modifiers: nocase, wide, ASCII, fullword

Provide the YARA rule below.

Exercise 4 - Poison Ivy

Purpose: Write a Yara rule that matches Poison Ivy malware family

Write a YARA rule for the Poison Ivy family that:

- Matches all ten Poison Ivy malware samples in a malicious directory
- Does not match any other files in malicious or benign directories
- Check that the file is a PE file
- Contains at least two non-generic strings
- Uses at least two of the following modifiers: nocase, wide, ascii, fullword
- Uses the ”at” and “pe.entry_point” keywords from PE module

Provide the YARA rule below.

End of Lab